Kanton Bern
Canton de Berne

Bildungs- und Kulturdirektion
Mittelschul- und Berufsbildungsamt

Austausch, Verarbeitung und Speicherung von Daten an Schulen Sek II

Leitfaden

Bearbeitungsdatum	19. Juni 2025
Version	2.0
Status	Freigegeben
Klassifizierung	nicht klassifiziert
Autor/-in	Digitalboard Schulen Sek II[1]

[1] André Huwiler - CTO WKS KV Bildung
Arnaud Forster - Responsable informatique pour la Direction et le secrétariat Gymnase de Bienne et du Jura bernois
Martin Studer - CDO Schulen Sek II BKD-MBA
Tom Jampen - Leitung Informatikdienste & Lehrperson Gymnasium Kirchenfeld
Urs Egli - Pädagogischer ICT-Support & Lehrperson BFB Biel-Bienne

Unterstützt durch
Michael Weber - Wissenschaftlicher Mitarbeiter Datenschutzaufsichtsstelle des Kantons Bern
Roger Keiser - ICT-Sicherheitsverantwortlicher BKD
Wasescha Raphaela - Wissenschaftliche Mitarbeiterin Rechtsdienst, Qualitätsentwicklung, Compliance BKD-MBA

Inhalt

1. Einleitung ... 3
1.1 Zielsetzung und Geltungsbereich ... 3
1.2 Verantwortung ... 3
1.3 Begriffsdefinitionen ... 4
1.4 Weiterführende Dokumente ... 5

2. Ermittlung des Schutzbedarfs von Informationen ... 6
2.1 Klassifizierung von Informationen ... 6
2.2 Überblick über die Klassifizierungsstufen ... 6

3. Austausch, Verarbeitung und Speicherung von Daten ... 7

4. Nutzung von KI-Systemen ... 8
4.1 Technische Risiken bei der Nutzung generativer KI-Systeme ... 8
4.2 Pädagogischer Einsatz generativer KI mit Klassen ... 8

5. Einsatz von kantonalen Diensten ... 9
5.1 Einsatz von M365 über EDUBERN ... 9
5.2 Einsatz von Evento ... 9

6. Optimierung beim Umgang mit als vertraulich klassifizierten Daten ... 10
6.1 Melde dich bei Schwierigkeiten ... 10
6.2 Empfehlung und Förderung einer Private-Cloud-First-Infrastruktur ... 10

7. Ergänzende Grundsätze ... 11
7.1 Grundsätze beim Umgang mit Daten von Schülerinnen, Schülern und Lernenden ... 11
7.2 Sicherer Umgang mit Daten in digitalen Systemen ... 11
7.2.1 Vertraulichkeit (z. B. Schutz vor Datenabfluss) ... 11
7.2.2 Integrität (z. B. korrekte Dateneingabe) ... 12
7.2.3 Verfügbarkeit (z. B. zuverlässige Datenhaltung) ... 13
7.3 Grundsätze bei der Entwicklung von Softwarelösungen ... 14
7.4 Digitale Souveränität ... 15

8. Änderungskontrolle ... 16

1. Einleitung

1.1 Zielsetzung und Geltungsbereich

Digitale Werkzeuge und Plattformen haben eine grosse Bedeutung im Bildungsbereich. Cloud- und KI-Dienste bieten Schulen umfassende und flexible Lösungen, die Lehrpersonen, Lernenden sowie Verwaltungsteams zahlreiche Möglichkeiten eröffnen, effektiver und kollaborativer zu arbeiten und zu lernen.

Mit diesen Chancen gehen jedoch auch Risiken einher, insbesondere beim Einsatz von Public-Cloud- und KI-Diensten. Die unreflektierte Nutzung solcher Technologien kann zu erheblichen Datenschutz- und Sicherheitsproblemen führen. Zu den zentralen Herausforderungen zählen:

- **Unachtsamer Umgang mit personenbezogenen Daten:** Bei deren Nutzung besteht die Gefahr, dass Mitarbeitende und Lehrpersonen personenbezogene Daten unbeabsichtigt und nicht datenschutzkonform mit den bereitgestellten Tools bearbeiten oder speichern.
- **Verlust der Datenkontrolle:** Die Speicherung und Verarbeitung von Daten in externen Systemen kann dazu führen, dass Schulen die Kontrolle über ihre Daten teilweise oder ganz abgeben. Dadurch kann nicht mehr mit Sicherheit garantiert werden, wo, wie und von wem die Daten bearbeitet werden, was die Vertraulichkeit und Integrität der Daten gefährden kann.
- **Rechtliche und ethische Unsicherheiten:** Nicht vollständig nachvollziehbare Technologien können rechtliche Anforderungen unterlaufen und werfen ethische Fragen im Umgang mit digitaler Privatsphäre auf - insbesondere bei einer verpflichtenden Nutzung.
- **Abhängigkeit von Anbietern (Lock-in-Effekt):** Proprietäre Lösungen können eine starke Bindung an bestimmte Anbieter erzeugen. Ein Anbieterwechsel ist häufig mit erheblichem Aufwand, hohen Kosten und potenziellem Datenverlust verbunden.

Ziel dieses Leitfadens ist es, Schulen eine praxisorientierte Orientierung für den datenschutzkonformen Umgang mit klassifizierten Informationen sowie zur sicheren Nutzung von Cloud- und KI-Diensten zu bieten.

1.2 Verantwortung

Die Verantwortung für die datenschutzkonforme und sichere Nutzung von Cloud- und KI-Diensten und anderen Datenspeichern liegt bei den jeweils zuständigen Funktionsträgern - beispielsweise bei der Schulleitung bei schulintern einheitlich eingesetzten Systemen (z. B. M365, Nextcloud, …) oder bei einzelnen Lehrpersonen, wenn sie spezifische Softwarelösungen für den Unterricht einsetzen.

Vor dem Einsatz solcher Lösungen ist die Schule verpflichtet, eine ISDS-Analyse (Informationssicherheit und Datenschutz-Analyse) durchzuführen. Liegt ein erhöhtes Risiko für die Rechte betroffener Personen vor, muss ein ISDS-Konzept - neu als Datenschutz-Folgenabschätzung bezeichnet - erstellt werden und soweit die Voraussetzungen nach KDSG erfüllt sind, der zuständigen Datenschutzaufsichtsstelle vorab zur Prüfung vorgelegt werden.

1.3 Begriffsdefinitionen

Begriff	Definition
Public Cloud	Online-Dienst, der Daten speichert und diese jederzeit über das Internet abrufbar macht. Sie wird von einem externen Anbieter betrieben und steht einer Vielzahl von Nutzern zur Verfügung. Die Ressourcen wie Server, Speicher und Anwendungen werden gemeinsam genutzt, was Skalierbarkeit und Kosteneffizienz ermöglicht. Die Sicherheits- und Datenschutzmassnahmen werden vom Cloud-Anbieter verwaltet. Beispiele: Microsoft 365, Apple iCloud, Dropbox, Google Workspace u. a.
Private Cloud	Dedizierte Cloudumgebung, die ausschliesslich für die eigene Institution betrieben wird. Sie bietet eine hohe Kontrolle über Sicherheit, Datenschutz und Konfiguration, da die Infrastruktur entweder im eigenen Rechenzentrum der Organisation oder bei einem externen Dienstleister gehostet wird. Der Zugriff auf die Private Cloud ist auf autorisierte Benutzer beschränkt, was eine höhere Sicherheit gewährleistet. Beispiele: Nextcloud HUB, openDesk u.a.
Private-Cloud-First-Infrastruktur	Private-Cloud-First-Infrastruktur bezeichnet eine IT-Strategie, bei der eine Institution vorrangig auf private Cloud-Umgebungen setzt, bevor alternative Infrastrukturmodelle wie die Public Cloud in Betracht gezogen werden. Die Private Cloud dient dabei als primäre Plattform für Anwendungen, Datenverarbeitung und IT-Services, während Public-Cloud-Dienste lediglich ergänzend und in speziellen Ausnahmefällen zum Einsatz kommen. Mit der Private-Cloud-First-Strategie sollen die Innovationspotenziale moderner Cloud-Technologien genutzt werden, ohne Kompromisse bei Sicherheit, Kontrolle und regulatorischer Compliance einzugehen.
Fachapplikation	Spezialisierte Softwarelösung, die für spezifische Aufgaben oder Prozesse für eine oder sämtliche kantonalen Schulen entwickelt oder ausgewählt wird. Sie dient der Unterstützung fachlicher Anforderungen eines bestimmten Arbeitsbereichs und ist auf dessen Bedürfnisse abgestimmt. Fachapplikationen integrieren sich häufig in bestehende IT-Landschaften und ermöglichen eine gezielte Automatisierung und Effizienzsteigerung in klar definierten Anwendungsfeldern. Der Zugriff erfolgt meist über autorisierte Benutzer und ist häufig rollenbasiert geregelt. Beispiele: Evento, Escada, Digitales Klassenbuch u.a.
HYOK-Verschlüsselung	Hold Your Own Key (HYOK) ist eine Verschlüsselungsmethode, bei der Unternehmen ihre eigenen Verschlüsselungsschlüssel behalten und verwalten, um die alleinige Kontrolle über den Zugriff auf ihre Daten zu gewährleisten.
Klassifizierung	Systematische Zuteilung von Informationen zu einer spezifischen Schutzstufe, basierend auf ihrer Sensibilität, Vertraulichkeit und dem potenziellen Schaden, der durch unbefugten Zugriff oder Verlust entstehen könnte.
M365	Softwarepakte von Public Cloud-basierten Anwendungen und Diensten, die von Microsoft entwickelt wurde
ISDS	Informationssicherheit und Datenschutz
MFA	Multi-Faktor-Authentifizierung Nutzer muss sich über zwei oder mehr Faktoren identifizieren (z.B. Passwort und Authenticator-App oder SMS-Code)
DSA	Datenschutzaufsichtsstelle des Kantons Bern
KI	Generative Künstliche Intelligenz (KI) ist ein Teilbereich der KI, der sich auf die Erstellung neuer Inhalte konzentriert. Diese Inhalte können in unterschiedlichen Formaten vorliegen, darunter Text, Bilder, Musik, und Videos. Im Gegensatz zur diskriminativen KI, die auf die Klassifizierung und Vorhersage von Daten abzielt - beispielsweise, um zu entscheiden, ob eine E-Mail Spam ist oder nicht -, erzeugen generative KI-Systeme neue Daten, die den Eigenschaften der Trainingsdaten ähneln.

1.4 Weiterführende Dokumente

Nr.	Name	Link
[1]	Datenschutzgesetz vom 19. Februar 1986 (KDSG; BSG 152.04)	#
[2]	Privatim: Merkblatt Cloud-spezifische Risiken und Massnahmen	#
[3]	Datenschutzverordnung vom 22. Oktober 2008 (DSV; BSG 152.040.1)	#
[4]	Regierungsratsbeschluss «Restrisiken beim Einsatz von M365. Bericht des Amtes für Informatik und Organisation (KAIO)»	#
[5]	Direktionsverordnung über Informationssicherheit und Datenschutz (ISDS DV; BSG 152.040.2)	#
[6]	LCH Positionspapier - Künstliche Intelligenz in der Schule: Chancen nutzen, Herausforderungen Meistern	#

2. Ermittlung des Schutzbedarfs von Informationen

2.1 Klassifizierung von Informationen

Informationen zu klassifizieren heisst, ihren Schutzbedarf festzulegen. Dieser ist davon abhängig, welcher materielle oder immaterielle Schaden entstehen kann, wenn die Informationen Unbefugten bekannt gemacht werden. Alle, die Informationen schaffen oder beschaffen, sind für die richtige Klassifizierung sowie für deren sichere und datenschutzkonforme Verarbeitung und Speicherung verantwortlich.[2]

Enthält ein Dokument Informationen, die unterschiedlich zu klassifizieren sind, so gilt in jedem Fall das höhere Schutzniveau. Bei sämtlichen Informationen ist zudem immer das Need-to-know-Prinzip anzuwenden: Informationen dürfen nur jenen Personen zur Verfügung gestellt werden, die sie für ihre konkrete Aufgabe benötigen - nicht darüber hinaus.

2.2 Überblick über die Klassifizierungsstufen[3]

Klassifizierung	Beschreibung	Beispiele (nicht abschliessend)
GEHEIM	Personendaten als schwere Gefahr für die Sicherheit Einzelner (Leib, Leben, Freiheit)	Adressen von Personen in polizeilichen Zeugenschutzprogrammen, … *Im Schulumfeld sehr selten.*
VERTRAULICH	Besonders schützenswerte Personendaten und Informationen mit besonderer Geheimhaltung	AHV-Nummer, HR-Dokumente, religionsbezogene Angaben (darunter auch Dispensgesuche für religiöse Feiertage, Angabe darüber, ob Schweinefleisch gegessen wird, Befolgung des Ramadans etc.), Angaben über Allergien, Entschuldigungsschreiben, Arztzeugnisse, Absenzenlisten, Nachteilsausgleichdossiers, Informationen zu psychologischen oder medizinischen Befunden einzelner Personen, Zeugnisse, Serien zu Abschlussprüfungen, Disziplinarische Massnahmen, Sitzungsprotokolle mit Personenbezug (bspw. Kommunikation zu Gesundheitszustand von einzelnen Personen), polizeiliche Ermittlungen, Strafverfahren, Straftaten und die dafür verhängten Strafen oder Massnahmen, Notenspiegel als auch Notenlisten, Informationen über den Schulübertritt, formative Beurteilungen, Bild- und Tonaufnahmen (z.B. Portrait-Aufnahmen), …
INTERN	Allgemeine Personendaten oder schützenswerte Informationen	Klassenliste mit beispielsweise Angaben zu Adressen, Telefonnummern, Namen der Eltern oder Geschwister, E-Mail, Klasse, sowie Geburtsdatum, Sitzungsprotokolle ohne Personenbezug, Stundenplan (mit Angabe von Lehrpersonen), Schularbeiten ohne Bewertung, jedoch mit Namensnennung, Berichte über Projekte mit Namensnennung (ohne Portraitaufnahmen), …
NICHT KLASSIFIZIERT	Nicht personenbezogene Daten & öffentliche Informationen	Stundenplan (etwaige Angabe von Lehrpersonen ausschliesslich mit Kürzel), Ferienplan, allgemeine Schulinformationen, Projektarbeiten ohne Namensnennung, Unterrichtsvorbereitungen, Unterrichtsunterlagen, Kommunikation für die Öffentlichkeit, …

[2] Quelle: Leitfaden zur Nutzung von Microsoft 365 in der Kantonsverwaltung
[3] In Anlehnung an «Leitfaden zur Nutzung von Microsoft 365 in der Kantonsverwaltung», Dezember 2023

3. Austausch, Verarbeitung und Speicherung von Daten

Während der Austausch, die Verarbeitung und Speicherung für nicht klassifizierte und interne Informationen unkompliziert ist und kaum Beschränkungen unterliegt, sind vertrauliche und geheime Daten nur unter der Bedingung zu speichern, dass Drittpersonen keinen Zugang haben. Entscheidend dabei ist somit sowohl die Wahl geeigneter Softwarelösungen als auch den Umfang damit, um datenschutzkonformes Arbeiten so einfach wie möglich in den Arbeitsalttag zu integrieren.

		E-Mail[4]	**Public Cloud** z.B. Microsoft 365, Apple iCloud	**Private Cloud oder NAS**[5] z.B. NextCloud, NextCloud HUB, OpenDesk	**Lokale Festplatten, USB-Sticks**[6] mit Datenträgerverschlüsselung	**Fachapplikationen** z.B. Evento [5]
VERTRAULICH	Besonders schützenswerte Personendaten und Informationen mit besonderer Geheimhaltung	👎	👎	👍	👍	👍
INTERN	Allgemeine Personendaten oder schützenswerte Informationen	👍	👍	👍	👍	👍
NICHT KLASSIFIZIERT	Nicht personenbezogene Daten & öffentliche Informationen	👍	👍	👍	👍	👍

[4] Auf die Übermittlung vertraulicher Informationen per E-Mail ist zu verzichten. Vertrauliche Informationen können per Link auf ein entsprechend abgelegten Dokuments oder mittels dafür ausgelegter Systeme zur verschlüsselten E-Mail-Kommunikation übermittelt werden.
[5] Mit jeweils explizit erstellter Datenschutz-Folgenabschätzung mit positivem Prüfbericht der DSA
[6] Für persönliche Endgeräte (interne und externe Festplatten, USB-Sticks, etc.) ist eine Datenträgerverschlüsselung einzurichten. Dabei ist zu erwähnen, dass ein Passwortschutz nicht mit einer Verschlüsselung gleichzusetzen ist.
Bei vertraulichen und geheimen Daten ist zudem zu beachten, dass die Daten nach der Bearbeitung auf dem persönlichen Endgerät und dem Hochladen in den dafür vorgesehenen Speicher an allen anderen Orten unwiderruflich zu löschen sind.

4. Nutzung von KI-Systemen

Der Einsatz generativer KI-Systeme im schulischen Umfeld erfordert besondere Vorsicht, insbesondere im Hinblick auf Datenschutz und den Schutz von Minderjährigen. Die folgenden Grundsätze helfen dabei, typische Risiken zu vermeiden und den Einsatz datenschutzkonform zu gestalten.

4.1 Technische Risiken bei der Nutzung generativer KI-Systeme

Beim Einsatz generativer KI treten spezifische technische Risiken auf. Drei zentrale Gefahrenquellen sind zu berücksichtigen:

- **Datenabfluss:** Die Verwendung von KI-Lösungen, die permanent sämtliche Dokumente analysieren und cloudbasiert auswerten, ist zu untersagen, um einen ungewollten Abfluss von Personendaten zu verhindern (z. B. die in Desktop-Apps integrierte Version von Microsoft Copilot).
- **Dateneingabe:** Die Eingabe von Daten, die Personen eindeutig identifizieren, ist zu untersagen.
- **Datenhaltung:** Es ist zu beachten, dass Daten bereits während der Eingabe vom jeweiligen System gespeichert werden.

4.2 Pädagogischer Einsatz generativer KI mit Klassen

Im Unterricht dürfen keine KI-Systeme eingesetzt werden, bei denen sich Schülerinnen, Schüler und Lernende eindeutig gegenüber der generativen KI identifizieren müssen. Beim Einsatz generativer KI-Systeme (z.B. ChatGPT) ist somit darauf zu achten, keine personalisierten Accounts zu verwenden. Stattdessen sollten anonymisierte Benutzerkonten oder anonymisierende Plattformen (z.B. fobizz oder Brian), bei denen die Kommunikation mit der KI über einen vermittelnden Dienst und nicht direkt über einen persönlichen Zugang erfolgt, verwendet werden. Darüber hinaus empfiehlt sich die Verwendung des «Privatmodus» im Browser, um Rückschlüsse auf einzelne Personen zu vermeiden.

Der Einsatz von KI-Systemen, die potenziell zu einem Kontrollverlust führen - etwa Microsoft Copilot -, ist nicht datenschutzkonform.

Bei der Nutzung von KI liegen alle technischen und organisatorischen Massnahmen im Bereich des Datenschutzes - wie bei sämtlichen datenschutzrelevanten Themen - in der Verantwortung der jeweils zuständigen Funktionsträger.

5. Einsatz von kantonalen Diensten

5.1 Einsatz von M365 über EDUBERN

Für Schulen, welche Microsoft 365 von EDUBERN beziehen, gelten die gleichen Richtlinien und Vorgaben. Die von EDUBERN zur Verfügung gestellte Microsoft Cloud-Palette ist nicht zusätzlich oder speziell abgesichert und darf daher auch nicht für die Ablage von Daten der Klassifizierungen «vertraulich» und «geheim» genutzt werden. Für die Ablage von Daten der Klassifizierungen «vertraulich» steht den Kunden von EDUBERN der Service «Private Cloud Data Storage» (Nextcloud) zur Verfügung.

5.2 Einsatz von Evento

In Evento dürfen Daten der Klassifizierungen «nicht klassifiziert», «intern» und «vertraulich» gespeichert werden. Daten der Klassifizierung «geheim» dürfen nicht in Evento abgelegt werden.

6. Optimierung beim Umgang mit als vertraulich klassifizierten Daten

6.1 Melde dich bei Schwierigkeiten

Beim Umgang mit als vertraulich klassifizierten Daten - insbesondere bei besonders schützenswerten Personendaten - müssen entsprechende Regeln eingehalten werden, welche teilweise mit den aktuell verfügbaren Werkzeugen nur erschwert eingehalten werden können.

Hast du eine solche Tätigkeit entdeckt, bei welcher du die Regeln nicht effizient einhalten kannst? Bitte teile uns diese Tätigkeit mit, damit wir entsprechende Optimierungen der dir zur Verfügung gestellten Werkzeuge in die Wege leiten können.

Die Rückmeldungen, welche in diesem Formular gegeben werden, werden in folgenden Gremien besprochen:
- CoP Informationssicherheit und Datenschutz
- Digitalboard
- Steuerungsausschuss Umsetzung Digitalisierungsstrategie Schulen Sek II

Du kannst die Tätigkeit auch anonym und ohne Angabe deiner Kontaktdaten übermitteln:
https://nocodb.digitalboard.ch/dashboard/#/nc/form/1326300d-a6d1-4810-a42e-3319c52de94c

6.2 Empfehlung und Förderung einer Private-Cloud-First-Infrastruktur

Sowohl auf der Grundlage der rechtlichen Rahmenbedingungen und der Möglichkeit zur Kontrolle der Kostenentwicklung als auch unter Berücksichtigung der gesellschaftspolitischen Entwicklungen wird den Schulen empfohlen, die Einführung einer Private-Cloud-First-Infrastruktur zu prüfen. Unterstützung für entsprechende Projekte kann beim Digitalboard angefragt werden:
digitalboard-sek2@be.ch

7. Ergänzende Grundsätze

7.1 Grundsätze beim Umgang mit Daten von Schülerinnen, Schülern und Lernenden

Der verantwortungsvolle Umgang mit Daten im schulischen Kontext ist essenziell, um das Vertrauen von Lernenden und deren Familien zu stärken sowie ein sicheres und faires Lernumfeld zu gewährleisten. Insbesondere der Einsatz digitaler Softwarelösungen - darunter auch KI-gestützte Anwendungen - erfordert besondere Sensibilität und Sorgfalt. Die folgenden Grundsätze sollen dabei Orientierung bieten:

- **Schutz der Privatsphäre:** Sensible Daten sind mit grösster Sorgfalt zu behandeln, um die Privatsphäre von Schülerinnen, Schülern, Lernenden und Eltern zu wahren.
- **Vertrauensbildung:** Ein transparenter Umgang mit der Nutzung und Funktionsweise von Software stärkt das Vertrauen aller Beteiligten in den digitalen Bildungsprozess.
- **Vermeidung von Missbrauch:** Softwarelösungen müssen sorgfältig ausgewählt und genutzt werden, um Missbrauch personenbezogener Daten zu verhindern.
- **Digitale Verantwortung gegenüber Jugendlichen:** Minderjährige verdienen besonderen Schutz. Der Einsatz von Software hat stets das Wohl der Jugendlichen zu priorisieren.
- **Fairness sicherstellen:** Digitale Anwendungen, insbesondere generative KI, sollen eine gerechte Behandlung aller Lernenden gewährleisten und Diskriminierung vermeiden.
- **Minimierung von Sicherheitsrisiken**: Die eingesetzten digitalen Lösungen müssen dazu beitragen, Gefahren wie Identitätsdiebstahl oder Mobbing vorzubeugen.
- **Ethik und Verantwortung:** Der reflektierte Einsatz von Software im Unterricht unterstützt die ethische Integrität der Schule und stärkt deren öffentliches Ansehen.

7.2 Sicherer Umgang mit Daten in digitalen Systemen

Aus Sicht der **Informationssicherheit** stehen drei grundlegende Schutzziele im Zentrum des sicheren Umgangs mit Daten:

- **Vertraulichkeit** - Schutz vor unbefugtem Zugriff auf Daten
- **Integrität** - Schutz vor unbeabsichtigten oder absichtlichen Veränderungen
- **Verfügbarkeit** - Sicherstellung, dass Daten und Systeme zuverlässig nutzbar bleiben

Diese Ziele helfen dabei, digitale Systeme stabil, nachvollziehbar und widerstandsfähig zu betreiben.

Die folgenden Abschnitte geben praxisnahe Hinweise, wie Schulen die Schutzziele der Informationssicherheit effektiv umsetzen können.

7.2.1 Vertraulichkeit (z. B. Schutz vor Datenabfluss)

Vertraulichkeit bedeutet, dass sensible oder schützenswerte Daten nur von berechtigten Personen oder Systemen eingesehen oder genutzt werden dürfen. Ein häufiges Risiko stellt der **Datenabfluss** dar -

also die unbeabsichtigte oder unkontrollierte Weitergabe von Informationen. Dies kann auf verschiedenen Wegen geschehen, z. B. durch unsichere Übertragungswege, fehlerhafte Freigaben, Sicherheitslücken oder durch automatische Analysefunktionen digitaler Systeme, die aus scheinbar harmlosen Daten Rückschlüsse auf vertrauliche oder personenbezogene Informationen ziehen können.

Ausgewählte Massnahmen zur Gewährleistung der Vertraulichkeit:

- **Verschlüsselung:** Daten sollten sowohl bei der Übertragung als auch bei der Speicherung durch geeignete Verfahren verschlüsselt werden, um sie vor unbefugtem Zugriff zu schützen.
- **Zugangskontrollen:** Der Zugriff auf digitale Systeme und Daten muss durch personalisierte Benutzerkonten und geeignete Authentifizierungsverfahren (z. B. Zwei-Faktor-Login) abgesichert werden. Anschliessend ist sicherzustellen, dass nur autorisierte Personen Zugriff auf die jeweils benötigten Daten und Funktionen erhalten.
- **Anonymisierung oder Pseudonymisierung:** Wo immer möglich, sollten personenbezogene Daten so verändert werden, dass keine Rückschlüsse auf Einzelpersonen möglich sind - z.B. durch Verwendung von Initialen, Codes oder aggregierten Daten.
- **Need-to-know-Prinzip:** Daten sollten nur den Personen zur Verfügung gestellt werden, die sie für ihre konkrete Aufgabe benötigen - nicht darüber hinaus.
- **Protokollierung:** Der Zugriff auf sensible Daten sollte dokumentiert werden, um unberechtigte Zugriffe oder Missbrauch erkennen und nachverfolgen zu können.
- **Sensibilisierung der Nutzenden:** Lehrpersonen, Schülerinnen und Schüler sollten sich der Risiken durch unachtsame Dateneingabe oder Offenlegung bewusst sein. Dazu gehört auch ein sicherer Umgang mit persönlichen Informationen in digitalen Anwendungen.

7.2.2 Integrität (z. B. korrekte Dateneingabe)

Integrität bedeutet, dass Daten während ihrer Eingabe, Verarbeitung und Speicherung **vollständig, korrekt und unverändert** bleiben. Fehlerhafte oder manipulierte Eingaben können die Qualität von Ergebnissen oder Entscheidungen beeinträchtigen.

Ausgewählte Massnahmen zur Gewährleistung der Integrität:

- **Korrekte Dateneingabe:** Bereits bei der Eingabe sollte darauf geachtet werden, dass nur relevante und sachlich richtige Informationen erfasst werden. Tippfehler, unpassende Formate oder irrelevante Daten können zu Problemen führen.
- **Überprüfung und Validierung:** Eingaben sollten automatisch oder manuell auf Vollständigkeit, Richtigkeit und Plausibilität geprüft werden - etwa durch Pflichtfelder, Fehlermeldungen oder Kontrollinstanzen.
- **Verwendung zuverlässiger Datenquellen:** Die Nutzung geprüfter, vertrauenswürdiger Quellen für externe Daten ist wichtig, um Manipulationen oder Verfälschungen zu vermeiden.
- **Technische Prüfmechanismen:** Massnahmen wie Prüfsummen oder Hash-Werte helfen, Manipulationen von Daten zu erkennen und zu verhindern.
- **Versions- und Änderungsverfolgung:** Systeme sollten Änderungen an Daten nachvollziehbar dokumentieren, um versehentliche oder unberechtigte Änderungen erkennen zu können.

- **Autorisierte Bearbeitung:** Ausschliesslich entsprechend berechtigte Personen dürfen Eingaben verändern oder freigeben. Die Umsetzung kann z. B. über abgestufte Berechtigungsrollen erfolgen.

7.2.3 Verfügbarkeit (z. B. zuverlässige Datenhaltung)

Verfügbarkeit bedeutet, dass Informationen und Systeme bei Bedarf zuverlässig erreichbar sind - auch bei technischen Problemen, hoher Auslastung oder Störungen. Schulen sind auf die Verfügbarkeit digitaler Plattformen und gespeicherter Daten angewiesen, z. B. in der Administration, bei der Unterrichtsplanung, Kommunikation oder Leistungsdokumentation.

Ausgewählte Massnahmen zur Sicherstellung der Verfügbarkeit:

- **Redundanzstrategien:** Zur Sicherstellung einer hohen Verfügbarkeit sollten Systeme technisch so ausgestattet sein, dass auch bei Ausfällen einzelner Komponenten ein unterbrechungsfreier Betrieb möglich ist. Dies kann durch Massnahmen wie Spiegelung (z. B. RAID), Lastverteilung oder georedundante Speicherlösungen erreicht werden.
- **Datensicherung (Backups):** Backups ermöglichen die Wiederherstellung von Daten nach schwerwiegenden Vorfällen wie Systemfehlern, versehentlichem Löschen oder Schadsoftwarebefall. Sie sollten automatisiert, regelmässig und getrennt vom Live-System erfolgen.
- **Wiederherstellbarkeit nach Ausfällen:** Es sollten klare Massnahmen und Abläufe definiert sein, um nach einem Ausfall die betroffenen Systeme schnell wieder in Betrieb nehmen zu können. Dazu zählen automatisierte Wiederanlaufprozesse, getestete Notfallpläne, die regelmässige Überprüfung von Backup- und Wiederherstellungssystemen sowie die Festlegung und Kontrolle von Wiederanlaufzeiten (RTO - Recovery Time Objective, d. h. maximal zulässige Ausfallzeit) und Datenverlustgrenzen (RPO - Recovery Point Objective, d. h. maximal akzeptabler Datenverlustzeitraum)
- **Monitoring und Frühwarnsysteme:** Die kontinuierliche Überwachung digitaler Systeme hilft, potenzielle Fehler oder Überlastungen frühzeitig zu erkennen und zu beheben.
- **Regelmässige Wartung:** Durchführung und Dokumentation von Updates, Patches und Systemprüfungen zur Vermeidung technischer Störungen.
- **Skalierbarkeit:** Die technische Infrastruktur sollte so ausgelegt sein, dass auch bei vielen gleichzeitigen Zugriffen - etwa während Prüfungsphasen - die Systeme stabil bleiben.

7.3 Grundsätze bei der Entwicklung von Softwarelösungen

Bei der Entwicklung von Softwarelösungen im schulischen oder verwaltungsnahen Umfeld werden folgende Grundsätze empfohlen, um Transparenz, Nachhaltigkeit und die effiziente Verwendung öffentlicher Mittel sicherstellen zu können:

- **Prinzip «Public Money, Public Code»:** Software, die mit öffentlichen Mitteln finanziert wird, soll nach Möglichkeit als Open Source Software entwickelt und veröffentlicht werden. Dies ermöglicht eine transparente Nachvollziehbarkeit, fördert die Wiederverwendbarkeit von Komponenten durch andere öffentliche Stellen und reduziert mittel- bis langfristig Abhängigkeiten von proprietären Anbietern.
- **Modularität und Interoperabilität:** Softwarelösungen sollen modular aufgebaut sein und auf offenen Standards basieren. Damit wird eine flexible Weiterentwicklung sowie die Integration in bestehende Systeme erleichtert. Insellösungen sind zu vermeiden.
- **Nachhaltigkeit und Wartbarkeit:** Die langfristige Wartbarkeit und Weiterentwicklung muss bereits bei der Konzeption berücksichtigt werden. Dies umfasst eine saubere Dokumentation, nachvollziehbaren Quellcode und klare Prozesse für zukünftige Anpassungen und Pflege.
- **Datenschutz und Sicherheit:** Die Einhaltung datenschutzrechtlicher Vorgaben und die Umsetzung angemessener Sicherheitsstandards sind bereits im Entwicklungsprozess zu berücksichtigen («Privacy by Design» und «Security by Design»). Die Vermeidung unnötiger Datenverarbeitung und die Minimierung von Risiken für Nutzerinnen und Nutzer stehen im Vordergrund.
- **Partizipation und Nutzerzentrierung:** Entwicklungsvorhaben sollen unter aktiver Einbeziehung der späteren Nutzergruppen erfolgen. Die Bedürfnisse von Lehrpersonen, Schülerinnen und Schülern, Lernenden sowie administrativem Personal sind frühzeitig zu erheben und fortlaufend in den Entwicklungsprozess zu integrieren.
- **Vermeidung von Vendor-Lock-in:** Bei der Auswahl von Technologien und Dienstleistern ist darauf zu achten, dass keine einseitige Abhängigkeit entsteht. Die Möglichkeit zum Wechsel des Anbieters sowie zur Weiterentwicklung durch Dritte muss gewährleistet sein.
- **Frühzeitige ISDS-Analyse:** Bereits in der Konzeptphase ist wie in der Direktionsverordnung [6] festgehalten eine ISDS-Analyse durchzuführen. Insbesondere Systeme, welche On-Premise betrieben werden können, vereinfachen Abklärungen hinsichtlich Fragen rund um Datenschutz erheblich.

Die Einhaltung dieser Grundsätze dienen einer nachhaltigen und zukunftsorientierte Softwareentwicklung.

7.4 Digitale Souveränität

Digitale Souveränität bedeutet, als Schule die Kontrolle über eingesetzte digitale Technologien zu behalten - insbesondere in Bezug auf Daten, Infrastruktur und Software. Schulen sollten selbstbestimmt darüber entscheiden können, welche digitalen Werkzeuge verwendet werden, wie diese funktionieren und inwieweit sie die Rechte der Beteiligten wahren. Dabei geht es nicht nur um Datenschutz, sondern auch um Transparenz, Abhängigkeiten von Anbietern und langfristige Handlungsfähigkeit.

Ein zentrales Prinzip in diesem Zusammenhang ist **«Public Money, Public Code»** - also die Forderung, dass öffentlich finanzierte Software auch öffentlich zugänglich, nachvollziehbar und veränderbar sein sollte. Freie und quelloffene Software (Open Source) stärkt die digitale Selbstbestimmung, reduziert externe Abhängigkeiten und ermöglicht mehr Transparenz im Umgang mit Daten.

Wichtige Grundsätze zur Förderung digitaler Souveränität im schulischen Umfeld:

- **Transparenz durch offene Software:** Bevorzugt sollten Softwarelösungen eingesetzt werden, deren Funktionsweise nachvollziehbar ist - idealerweise durch Einsicht in den Quellcode oder durch umfassende Dokumentation. So kann sichergestellt werden, dass keine verdeckten Datenflüsse oder unerwünschten Funktionen enthalten sind.
- **Vermeidung von Anbieterabhängigkeit:** Proprietäre Systeme, die exklusiv an bestimmte Anbieter gebunden sind, erschweren langfristige Planung und Kontrolle. Der Einsatz von standardisierten, interoperablen Systemen ermöglicht flexiblere Entscheidungen.
- **Berücksichtigung freier und quelloffener Software (FOSS):** Wo immer möglich, sollte auf Open-Source-Lösungen zurückgegriffen werden. Diese bieten nicht nur erweiterbare Funktionalität und Sicherheit durch Offenheit, sondern minimieren auch das Risiko langfristig steigender Lizenzkosten. Zudem lassen sie sich flexibel auf schulische Bedürfnisse abstimmen und individuell zusammenstellen.
- **Technologische Unabhängigkeit als Bildungsziel:** Die kritische Reflexion über eingesetzte Technologien sowie die Fähigkeit, digitale Werkzeuge kompetent und bewusst zu wählen, ist Teil digitaler Bildung. Digitale Souveränität beginnt daher bereits im Unterricht und in der Ausstattung von Lern- und Arbeitsumgebungen.
- **Förderung datenschutzkonformer Alternativen:** Digitale Werkzeuge, die ohne Tracking, Profiling oder undurchsichtige Cloud-Infrastruktur auskommen, sollten bevorzugt werden - insbesondere, wenn es um personenbezogene Daten von Schülerinnen, Schülern und Lernenden geht.

Digitale Souveränität ist ein zentraler Bestandteil verantwortungsvoller Schulentwicklung im digitalen Zeitalter. Sie stärkt nicht nur den Schutz der Nutzenden, sondern auch die Kontrolle der Kostenentwicklung und Innovationsfähigkeit der Schulen Sek II im Kanton Bern.

8. Änderungskontrolle

Entwurf

Version	Bearbeiter*in	Datum	Bemerkungen
0.1	Urs Egli	14.11.2024	Entwurf erstellt
0.2	Urs Egli	12.12.2024	Überarbeitung
0.3	Digitalboard	09.01.2025	Anpassungen an den Kapitel Informationsaustausch und Dateiablagen.
0.4	Martin Studer	10.01.2025	Anpassungen Tabelle Dateiablagen
0.5	Martin Studer	10.02.2025	Anpassungen aufgrund Rückmeldungen Stab Recht & QE (MBA) eingearbeitet.
0.6	Martin Studer	02.04.2025	Tabellen Informationsaustausch und Kommunikation sowie Dateiablagen vereinfacht.
0.8	Martin Studer	05.05.2025	Änderungsvorschläge DSA eingearbeitet
0.9	Digitalboard	08.05.2025	Kapitel KI ergänzt
0.10	Martin Studer	13.05.2025	Kapitel «Ergänzende Grundsätze» ergänzt
0.11	Digitalboard	14.05.2025	Kapitel 1-6 redigiert.
0.13	Martin Studer	06.06.2025	Änderungsvorschläge DSA eingearbeitet & Überarbeitung Kapitel 7.2
1.1	Martin Studer	18.06.2025	Kapitel 4.2 redigiert.
1.2	Digitalboard	19.06.2025	Kapitel 4.2 besprochen und redigiert.

Review

Version	Bearbeiter*in	Datum	Bemerkungen
0.7	DSA	24.04.2025	Erstes Review durch DSA
0.12	DSA	05.06.2025	Review durch DSA

Freigegeben

Version	Bearbeiter*in	Datum	Bemerkungen
1.0	Digitalboard	13.06.2025	Versionsnummer angepasst. Freigabe erfolgte basierend auf der durch den Freigabeprozess freigegebenen Entwurfsversion 0.13
2.0	Digitalboard	19.06.2025	Versionsnummer angepasst. Freigabe erfolgte basierend auf der durch den Freigabeprozess freigegebenen Entwurfsversion 1.2